

ЛАБОРАТОРНАЯ РАБОТА №6

Пентестинг уязвимого сервера

Цель

Ознакомление с процедурой пентестинга удалённого сервера с использованием платформы Metasploit Framework и графической надстройки Armitage.

Задачи

В процессе выполнения лабораторной работы решаются следующие задачи:

1) Подготовка рабочей среды: запуск виртуальных машин, настройка сетевых интерфейсов и проверка сетевой связности между атакующим узлом Kali Linux и целевым сервером Metasploitable.

2) Сбор и анализ информации: сканирование целевого узла сетевым сканером Nmap, определение открытых TCP-портов, идентификация сервисов и их версий, а также идентификация операционной системы.

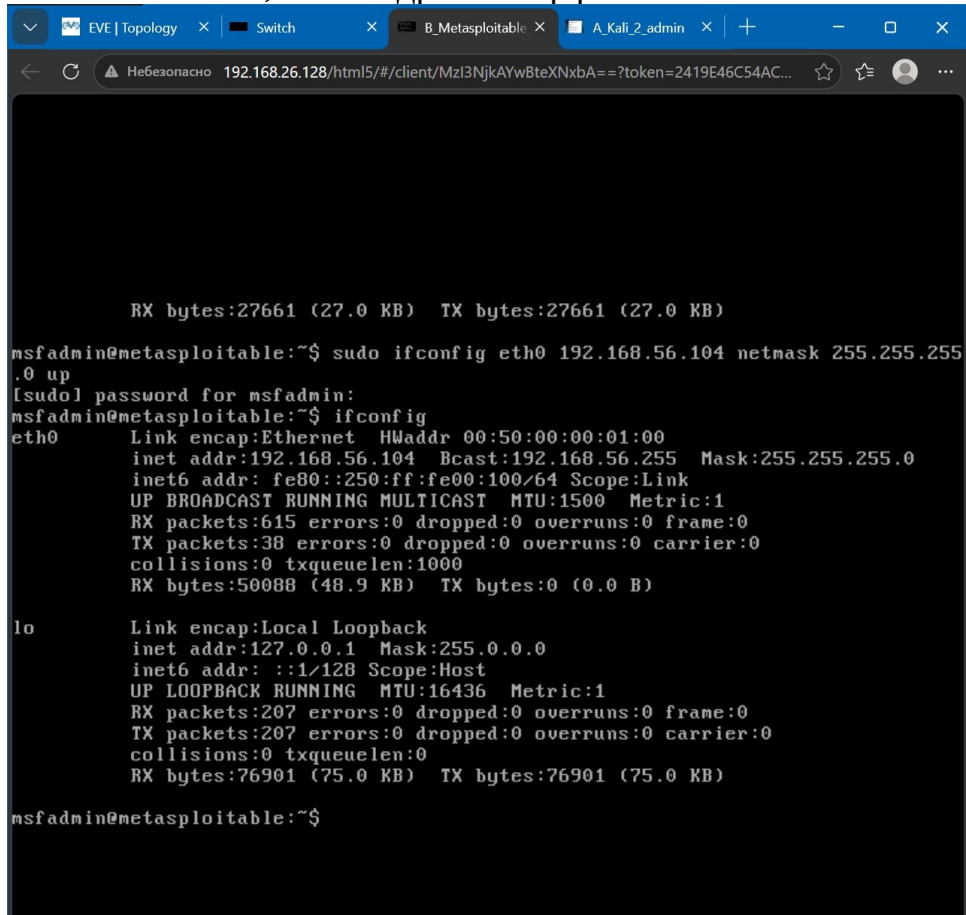
3) Поиск и использование уязвимостей: подбор эксплойтов средствами Armitage, проведение атаки на уязвимый сервис, получение несанкционированного доступа к целевой системе и формирование перечня выявленных уязвимостей с предложением мер по их устранению.

Лабораторная работа была выполнена на учебном стенде, развёрнутом в среде моделирования сетей EVE-NG (Community Edition 5.0.1). Стенд включает два узла, соединённых через виртуальный коммутатор и принадлежащих изолированному сегменту 192.168.56.0/24: атакующий узел A_Kali под управлением Kali GNU/Linux 2019.4 (ядро Linux, IP-адрес 192.168.56.103) и целевой узел B_Metasploitable под управлением Metasploitable 2 (Linux 2.6.24-16-server i686, IP-адрес 192.168.56.104). В качестве инструментария пентестинга использованы Nmap версии 7.80, Metasploit Framework версии 5 и графическая надстройка Armitage. Доступ к консолям виртуальных машин осуществлялся через HTML5-клиент EVE-NG в браузере.

Часть 1. Подготовка рабочей среды

Виртуальные машины A_Kali и B_Metasploitable были запущены в среде EVE-NG. На сервере Metasploitable был выполнен вход в систему с учётной записью msfadmin (пароль msfadmin). Поскольку в исходной конфигурации сетевой интерфейс целевого узла не имел назначенного IPv4-адреса, на интерфейсе eth0 был настроен статический адрес 192.168.56.104 с маской 255.255.255.0 командой `sudo ifconfig eth0 192.168.56.104 netmask 255.255.255.0 up`. Корректность настройки подтверждена выводом команды `ifconfig`: интерфейс eth0 находится в

состоянии UP BROADCAST RUNNING MULTICAST, ему назначен IP-адрес 192.168.56.104/24, MAC-адрес интерфейса — 00:50:00:00:01:00.



```

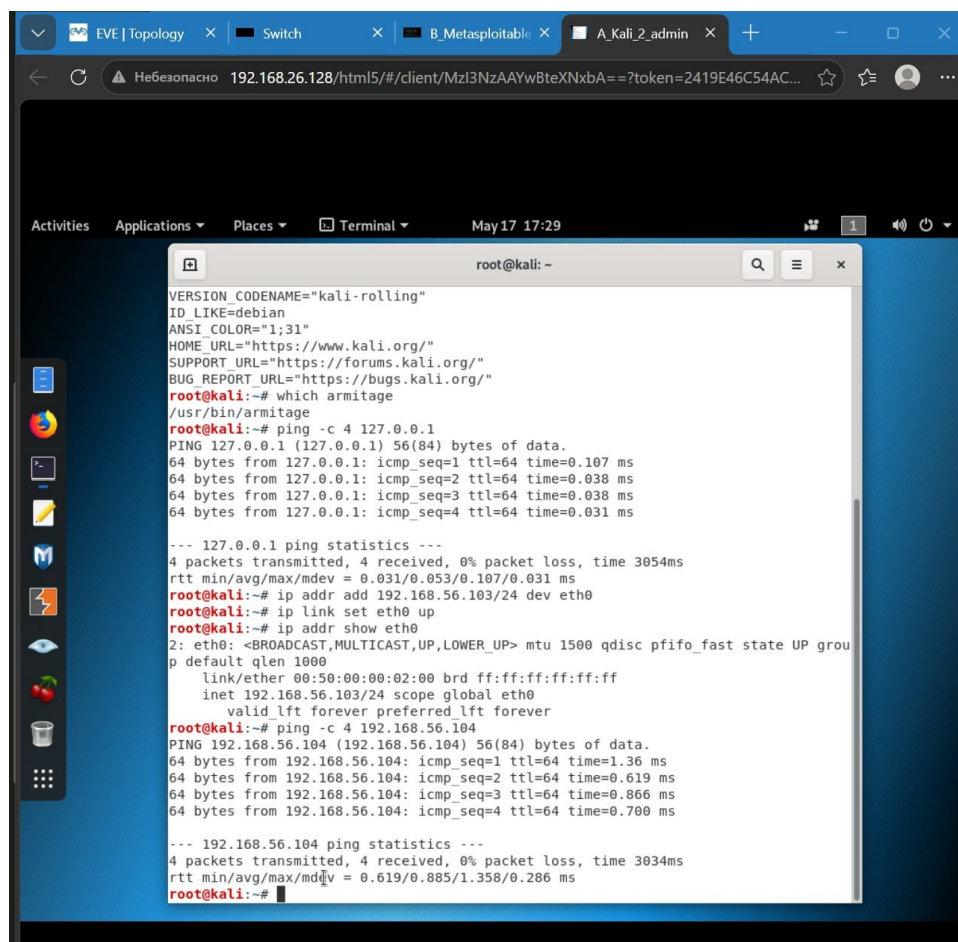
RX bytes:27661 (27.0 KB) TX bytes:27661 (27.0 KB)

msfadmin@metasploitable:~$ sudo ifconfig eth0 192.168.56.104 netmask 255.255.255.0 up
[sudo] password for msfadmin:
msfadmin@metasploitable:~$ ifconfig
eth0      Link encap:Ethernet  HWaddr 00:50:00:00:01:00
          inet addr:192.168.56.104  Bcast:192.168.56.255  Mask:255.255.255.0
          inet6 addr: fe80::250:ff:fe00:100/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:615 errors:0 dropped:0 overruns:0 frame:0
          TX packets:38 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:50088 (48.9 KB)  TX bytes:0 (0.0 B)

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:207 errors:0 dropped:0 overruns:0 frame:0
          TX packets:207 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:76901 (75.0 KB)  TX bytes:76901 (75.0 KB)

msfadmin@metasploitable:~$
```

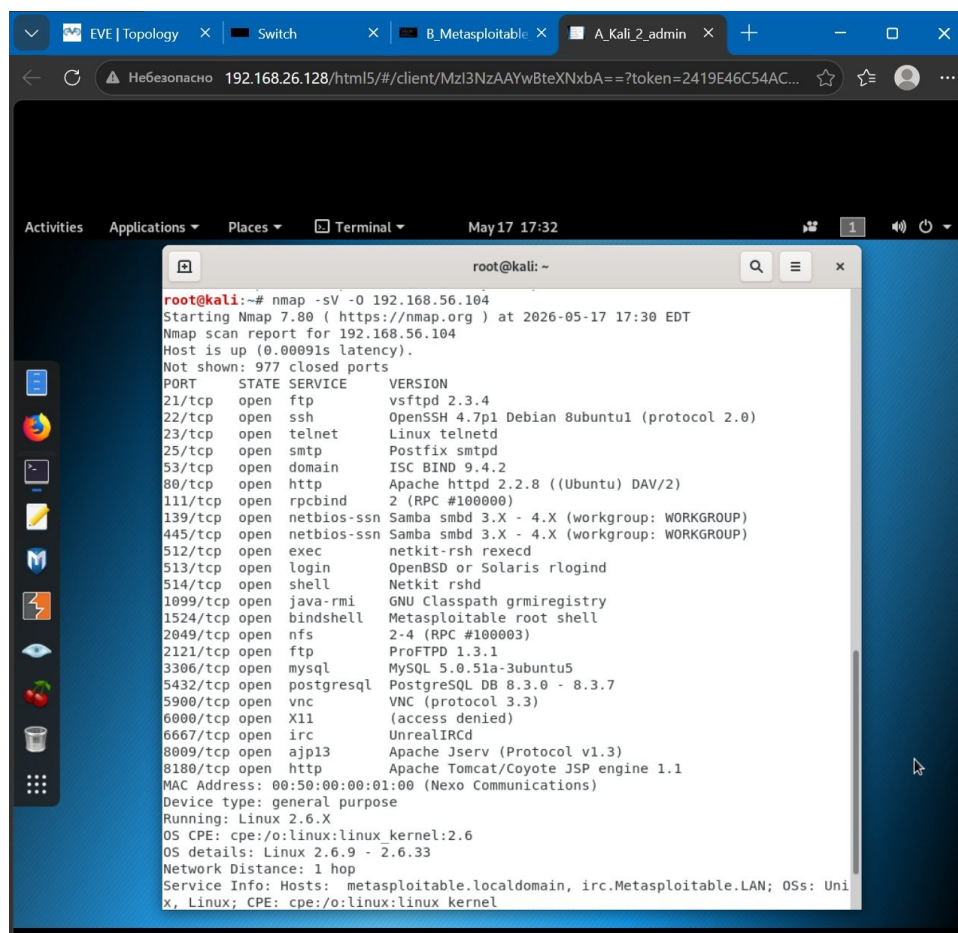
На атакующем узле Kali Linux был выполнен вход в систему с учётной записью root (пароль toor). Командой `cat /etc/os-release` была определена версия операционной системы — Kali GNU/Linux Rolling 2019.4; командой `which armitage` установлено наличие установленной графической надстройки Armitage по пути `/usr/bin/armitage`. На интерфейсе `eth0` был настроен статический IP-адрес 192.168.56.103 с маской 255.255.255.0 командой `ip addr add 192.168.56.103/24 dev eth0`, после чего интерфейс был переведён в активное состояние командой `ip link set eth0 up`. Корректность настройки подтверждена выводом команды `ip addr show eth0`. Проверка сетевой связности с сервером Metasploitable была выполнена командой `ping -c 4 192.168.56.104`: получены ICMP-ответы от всех четырёх эхо-запросов (потери пакетов 0 %, среднее время отклика 0,885 мс), что свидетельствует о наличии сетевой связности между узлами.



Часть 2. Сбор и анализ информации

Сбор информации о целевом сервере был выполнен сетевым сканером Nmap в два этапа: предварительное сканирование из терминала Kali Linux и последующее сканирование средствами Armitage с сохранением результатов в базе данных Metasploit Framework.

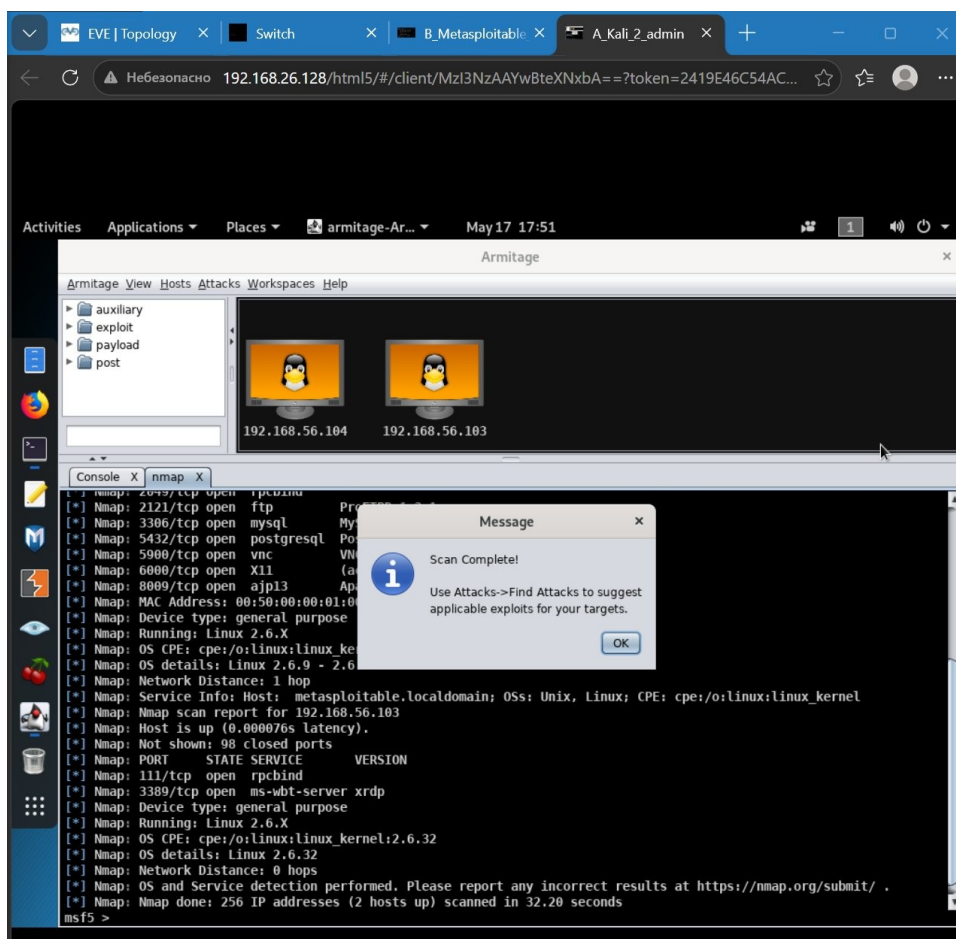
Предварительное сканирование было выполнено командой `nmap -sV -O 192.168.56.104`, объединяющей определение версий запущенных сервисов (ключ `-sV`) и идентификацию операционной системы по сигнатурам TCP/IP-стека (ключ `-O`). Сканирование завершено за 26,32 с. По результатам сканирования на целевом узле определено 23 открытых TCP-порта; операционная система идентифицирована как Linux 2.6.X с уточнением версии ядра 2.6.9 — 2.6.33 (CPE-идентификатор `cpe:/o:linux:linux_kernel:2.6`); MAC-адрес узла — 00:50:00:00:01:00. Перечень открытых портов с идентифицированными сервисами и их версиями приведён далее.



```
root@kali:~# nmap -sV -O 192.168.56.104
Starting Nmap 7.80 ( https://nmap.org ) at 2026-05-17 17:30 EDT
Nmap scan report for 192.168.56.104
Host is up (0.00091s latency).
Not shown: 977 closed ports
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rexecd
513/tcp   open  login        OpenBSD or Solaris rlogind
514/tcp   open  shell        Netkit rshd
1099/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)
6000/tcp  open  X11          (access denied)
6667/tcp  open  irc          UnrealIRCd
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 00:50:00:00:01:00 (Nexo Communications)
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel
```

Для последующего использования инструментария Armitage в терминале Kali Linux была запущена служба базы данных PostgreSQL командой `service postgresql start`, после чего командой `msfdb init` выполнена проверка инициализации базы данных Metasploit Framework (получено сообщение о том, что база данных уже сконфигурирована и инициализация не требуется). Запуск Armitage был выполнен командой `armitage`; в окне Connect параметры подключения к RPC-серверу `msfrpcd` оставлены без изменений (хост 127.0.0.1, порт 55553, пользователь `msf`, база данных `msf`), после чего выполнено подключение. Загрузка модулей Metasploit Framework заняла приблизительно одну минуту.

Сервер Metasploitable был добавлен в рабочее пространство Armitage через меню `Hosts` → `Add Hosts` с указанием IP-адреса 192.168.56.104. С целью идентификации операционной системы и сервисов средствами Armitage было выполнено сканирование сети 192.168.56.0/24 через меню `Hosts` → `Nmap Scan` → `Quick Scan (OS detect)`; фактически отправленная Armitage команда — `db_nmap --min-hostgroup 96 -sV -n -T4 -O -F --version-light 192.168.56.0/24`. Сканирование завершено за 32,20 с; в подсети обнаружено два активных узла — атакующий 192.168.56.103 и целевой 192.168.56.104, оба идентифицированы как узлы под управлением операционной системы семейства Linux, что отражено в виде соответствующих графических иконок в рабочем пространстве Armitage.

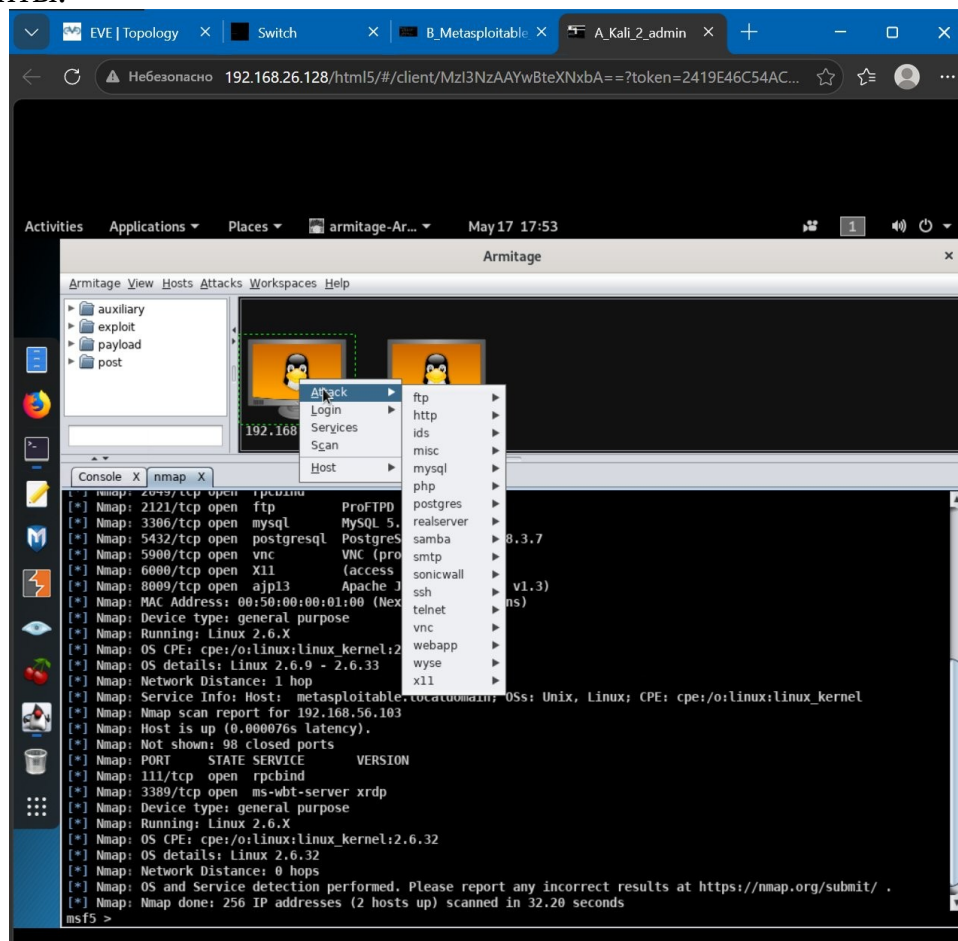


На основании полученных при сканировании сведений было сформировано предварительное представление о возможных направлениях атаки. На целевом сервере выявлен ряд устаревших версий сетевых сервисов с известными уязвимостями, в том числе: vsftpd 2.3.4 на порту 21/tcp (известный бэкдор в исходных кодах официального дистрибутива), Samba smbd версий 3.X — 4.X на портах 139/tcp и 445/tcp (уязвимость командной инъекции в обработчике username map script), UnrealIRCd на порту 6667/tcp (преднамеренная закладка в дистрибутиве версии 3.2.8.1), Linux telnetd на порту 23/tcp и службы r-* на портах 512 — 514/tcp (передача учётных данных в открытом виде и отсутствие надёжной аутентификации), MySQL 5.0.51a на порту 3306/tcp и PostgreSQL 8.3 на порту 5432/tcp (известные конфигурации со слабыми учётными данными), Apache Tomcat/Coyote JSP engine 1.1 на порту 8180/tcp (стандартные учётные данные администратора менеджера приложений), а также прослушиваемый bindshell на порту 1524/tcp (изначально открытый корневой командный интерпретатор).

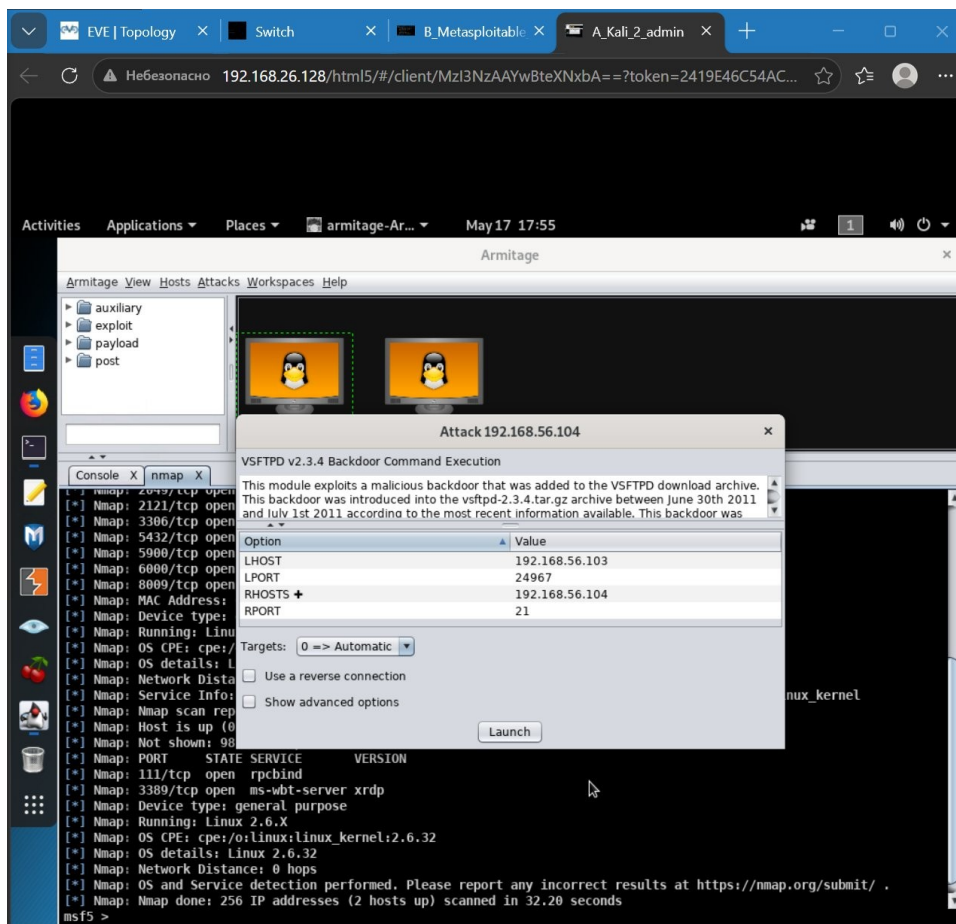
Часть 3. Поиск и использование уязвимостей

С использованием меню Attacks → Find Attacks в графической надстройке Armitage был выполнен автоматический подбор модулей Metasploit Framework, соответствующих выявленным сервисам. По завершении подбора в контекстном меню целевого узла стало доступно

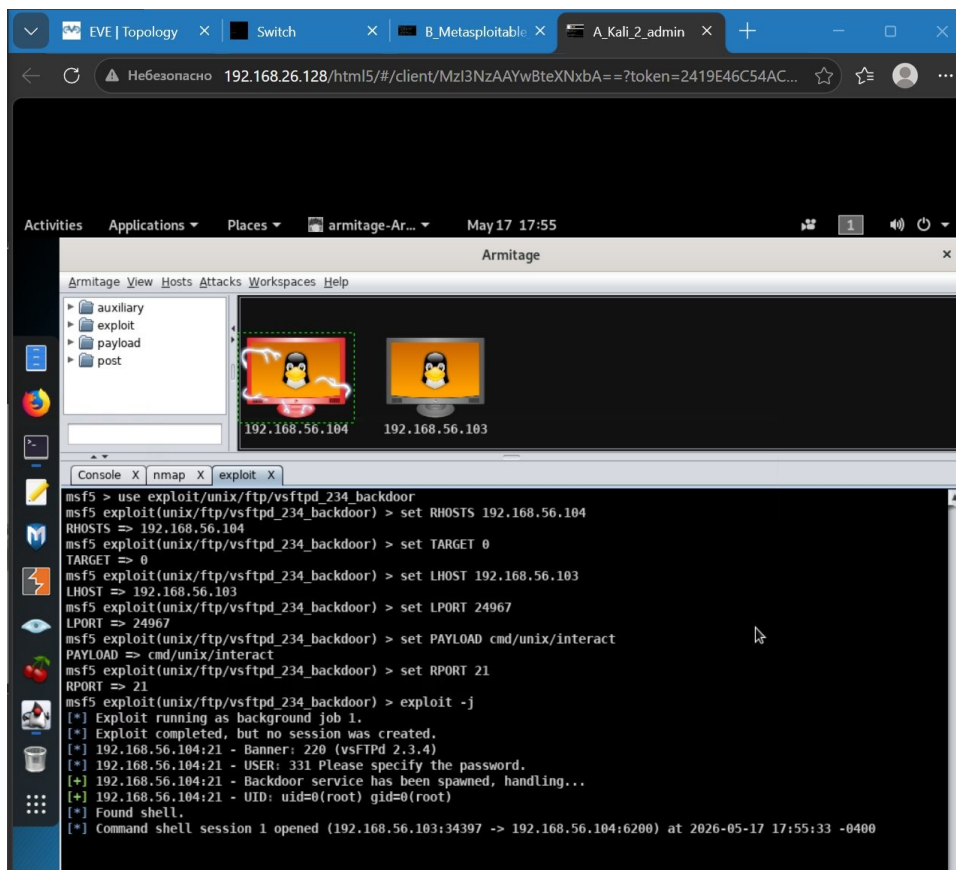
подменю Attack, содержащее сгруппированные по типам сервисов эксплойты.



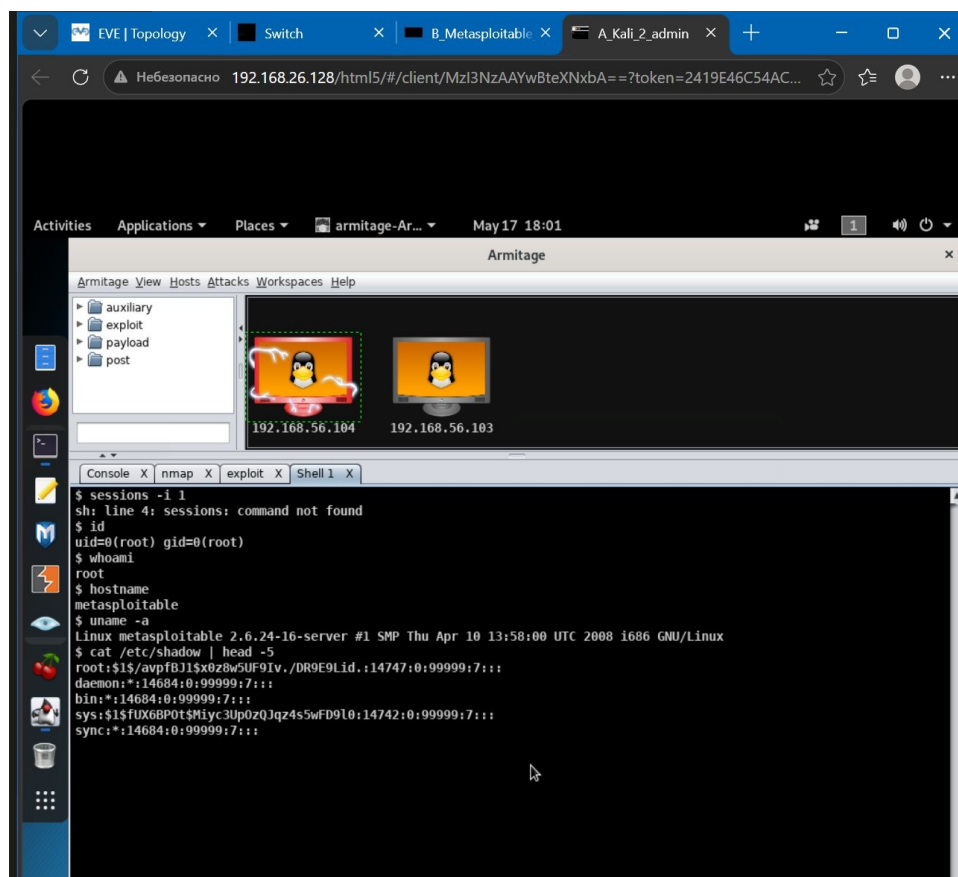
В качестве моделируемой атаки использовался эксплойт vsftpd_234_backdoor (модуль exploit/unix/ftp/vsftpd_234_backdoor) — атака внедрения команд, направленная на FTP-сервис vsftpd версии 2.3.4. Концепция атаки заключается в отправке на порт 21/tcp специально сформированной последовательности байт (имени пользователя, оканчивающегося символами «:»)), которая в скомпрометированном дистрибутиве vsftpd 2.3.4 активирует ранее внедрённый бэкдор и приводит к открытию корневого командного интерпретатора на порту 6200/tcp. Выбор эксплойта был выполнен через подменю Attack → ftp → vsftpd_234_backdoor; в открывшемся окне настройки параметров атаки значения RHOSTS = 192.168.56.104 и RPORT = 21 были автоматически подставлены Armitage из базы данных Metasploit Framework, параметры LHOST = 192.168.56.103 и Target = 0 (Automatic) оставлены без изменений.



Запуск атаки был выполнен нажатием кнопки Launch. По результатам выполнения эксплойта в консоли Metasploit Framework последовательно зафиксированы события: получение баннера сервера 220 (vsFTPd 2.3.4), отправка вредоносного имени пользователя, ответ сервера 331 Please specify the password, активация бэкдора на порту 6200/tcp (сообщение Backdoor service has been spawned, handling...) и установление сессии командного интерпретатора. Идентификатор пользователя, под которым выполняется командный интерпретатор на целевом узле, определён сообщением UID: uid=0(root) gid=0(root), что свидетельствует о получении максимальных полномочий в операционной системе целевого узла. Открытие сессии подтверждено сообщением Command shell session 1 opened (192.168.56.103:34397 → 192.168.56.104:6200); графическое отображение скомпрометированного узла в рабочем пространстве Armitage было изменено с обычной иконки узла Linux на иконку с красной молнией.



Постэксплуатация заключалась во взаимодействии с полученной сессией командного интерпретатора через вкладку Shell 1. Идентификатор пользователя был подтверждён выводом команд `id` (`uid=0(root) gid=0(root)`) и `whoami` (`root`). Имя узла, на котором выполняется командный интерпретатор, было определено командой `hostname` (`metasploitable`). Сведения о ядре операционной системы получены командой `uname -a`: `Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux`. С целью демонстрации полученных полномочий было выполнено чтение первых пяти строк файла `/etc/shadow` командой `cat /etc/shadow | head -5`; в полученном выводе видны хэши паролей системных учётных записей `root` и `sys` в формате MD5-crypt (`$1$...`), что свидетельствует о получении полного доступа к конфиденциальной информации целевого узла.



Перечень выявленных уязвимостей и меры по их устранению

По результатам сканирования и анализа сервисов целевого узла был сформирован перечень выявленных уязвимостей, включающий не менее пяти наименований.

1) Бэкдор в FTP-сервисе vsftpd 2.3.4 (CVE-2011-2523, порт 21/tcp). Уязвимость заключается во вредоносном коде, внедрённом в официальный дистрибутив vsftpd версии 2.3.4 в 2011 году и приводящем к открытию корневого командного интерпретатора на порту 6200/tcp при поступлении специально сформированного запроса аутентификации. Уязвимость была успешно эксплуатирована в настоящей работе. Мера по устранению: обновление FTP-сервиса до актуальной версии vsftpd (3.x), полученной из доверенного источника.

2) Уязвимость командной инъекции в обработчике username map script сервиса Samba 3.x (CVE-2007-2447, порты 139/tcp, 445/tcp). Уязвимость позволяет неаутентифицированному злоумышленнику выполнить произвольные команды операционной системы с полномочиями процесса smbd при специальном формировании поля имени пользователя. Мера по устранению: обновление Samba до актуальной версии 4.x с поддержкой исправления данной уязвимости либо отключение опции username map script в конфигурации сервиса при отсутствии необходимости в её использовании.

3) Закладка в исходных кодах сервера IRC UnrealIRCd 3.2.8.1 (CVE-2010-2075, порт 6667/tcp). Уязвимость заключается во вредоносном коде,

внедрённом в официальный дистрибутив UnrealIRCd 3.2.8.1 и позволяющем удалённому злоумышленнику выполнить произвольные команды операционной системы. Мера по устранению: удаление сервиса UnrealIRCd либо обновление до актуальной версии (4.x или 5.x), полученной из доверенного источника.

4) Использование устаревших сетевых сервисов с передачей учётных данных в открытом виде: telnet (порт 23/tcp), rexec (512/tcp), rlogin (513/tcp), rsh (514/tcp). Указанные сервисы не обеспечивают криптографической защиты передаваемых данных и допускают перехват учётных записей средствами сетевого анализа трафика; службы r-* дополнительно используют слабую модель доверия на основе IP-адресов и файлов .rhosts. Мера по устранению: отключение указанных сервисов и переход на защищённый протокол удалённого доступа SSH.

5) Предустановленный bindshell на порту 1524/tcp. На целевом узле в режиме прослушивания на порту 1524/tcp функционирует командный интерпретатор без какой-либо аутентификации, доступ к которому возможен по подключению произвольным TCP-клиентом (например, nc 192.168.56.104 1524) с получением максимальных полномочий. Мера по устранению: удаление соответствующей службы из автозапуска (inetd / xinetd) и закрытие порта на межсетевом экране.

6) Слабые учётные данные администратора менеджера приложений Apache Tomcat (порт 8180/tcp). Сервис допускает аутентификацию с предустановленными парами имя пользователя — пароль (tomcat:tomcat, admin:admin и аналогичные), что позволяет загрузку и развёртывание произвольных веб-приложений с возможностью выполнения кода. Мера по устранению: изменение учётных данных по умолчанию, ограничение доступа к интерфейсу менеджера приложений на уровне меж сетевого экрана либо отключение интерфейса при отсутствии необходимости в его использовании.

Помимо устранения отдельных уязвимостей, рекомендуется применение организационно-технических мер общего характера: регулярное обновление программного обеспечения, ограничение перечня запущенных сетевых сервисов до минимально необходимого, использование меж сетевого экрана для фильтрации входящего трафика на портах нецелевых сервисов, применение системы обнаружения вторжений, регулярное проведение аудита защищённости и сканирования уязвимостей.

Вывод

Изучена процедура пентестинга удалённого сервера с использованием платформы Metasploit Framework и графической надстройки Armitage на примере уязвимого сервера Metasploitable 2. На этапе подготовки рабочей среды настроена сетевая связность между

атакующим узлом Kali Linux (192.168.56.103) и целевым сервером (192.168.56.104). На этапе сбора и анализа информации средствами Nmap (как из терминала Kali Linux, так и из интерфейса Armitage) на целевом узле выявлено 23 открытых TCP-порта, идентифицированы запущенные сервисы и их версии, а также определена операционная система — Linux 2.6.24 (Metasploitable 2). На этапе поиска и использования уязвимостей средствами Armitage был выбран и успешно применён эксплойт vsftpd_234_backdoor: использование бэкдора в FTP-сервисе vsftpd 2.3.4 позволило получить корневой командный интерпретатор на целевом узле (UID 0) без какой-либо аутентификации, что подтверждено выводом команд id, whoami, hostname и uname -a и чтением файла /etc/shadow, содержащего хэши паролей системных учётных записей. По результатам сканирования сформирован перечень из шести наименований выявленных уязвимостей с предложением технических мер по их устранению, основными из которых являются обновление уязвимого программного обеспечения до актуальных версий, отключение устаревших и не обеспечивающих криптографической защиты сетевых сервисов, изменение предустановленных учётных данных и фильтрация сетевого трафика на уровне межсетевого экрана.